

SOC/L1 - 5. Phishing Analysis and OSINT Tools

1. Phishing Analysis Fundamentals

Task 1 - Introduction

Spam and phishing are the most common social engineering threats, with phishing posing a higher risk by tricking users into revealing sensitive data or installing malware. A single careless action, like clicking a malicious link, can compromise an entire network. Defenders must analyze email content to determine if messages are malicious and use that information to improve security and prevent future attacks.

A phishing campaign is a coordinated series of fraudulent messages, usually emails, designed to trick people into revealing sensitive information or installing malware. It often uses fake websites, spoofed senders, and social engineering to make the message look trustworthy.

Task 2 - The Email Address

where an email is composed of the following elements:

1. Username: User mailbox that identifies the specific recipient's mailbox on the email server
2. @ symbol: Separates the username from the domain and tells the system where to route the email
3. Domain name: Specifies the mail server responsible for receiving the message

Answer the questions below

Identify the domain used in the following email address:
hatsalesman@tryhatme.com. tryhatme.com

Task 3 - Email Delivery

Each protocol has a specific role:

- **Simple Mail Transfer Protocol (SMTP):** Sends emails
- **Post Office Protocol (POP3):** Downloads emails to a device
- **Internet Message Access Protocol (IMAP):** Syncs emails across devices

When receiving emails, your email service will use either POP3 or IMAP, depending on how your mailbox is configured. Let's take a look at both of these protocols below:

POP3

- Emails are downloaded and stored on a single device
- Sent messages are stored on the single device from which the email was sent
- Emails can only be accessed from the single device to which the emails were sent
- Emails are typically removed from the server after download

IMAP

- Emails are stored on the server and can be downloaded to multiple devices
- Sent messages are stored on the server
- Syncs messages across multiple devices
- Emails remain on the server unless explicitly deleted

An Email's Journey: An email is sent from a user's client to their mail server using SMTP. The server queries DNS to find the recipient's mail server, then delivers the message over the internet. The recipient's email client connects to their server and retrieves the email using POP3 or syncs it via IMAP.

Answer the questions below

Which protocol is responsible for sending an email from a client to a mail server? SMTP

Which service is used to look up the recipient domain's mail server? DNS

Bob wants to access his email from multiple devices, including his phone and laptop.

Which protocol should he use? IMAP

Task 4 - Email Headers

An email consists of two main parts:

- **Email header:** Contains metadata about the message, such as sender and the servers involved in delivery
- **Email body:** Contains the actual message content, which may be plain text or HTML

Email Headers: In your VM, open up the `email1.eml` file in the `Email Samples` folder on your desktop.

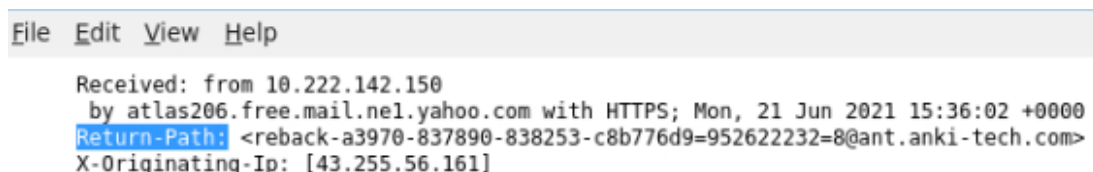
1. **From:** The sender's email address
2. **To:** The receiver's email address
3. **Reply to:** Address where replies are sent (not required)
4. **Subject:** The email's subject line
5. **Date:** The time and date that the email was sent

Viewing the Message Source: Viewing the email source displays the full raw message, including all header fields and the email body, which may contain plain text or HTML.

1. Navigate to the View menu
2. Choose Message Source

Answer the questions below

What is the full subject line of email1.eml? Return-Path



```
File Edit View Help
Received: from 10.222.142.150
by atlas206.free.mail.ne1.yahoo.com with HTTPS; Mon, 21 Jun 2021 15:36:02 +0000
Return-Path: <reback-a3970-837890-838253-c8b776d9=952622232=8@ant.anki-tech.com>
X-Originating-Ip: [43.255.56.161]
```

View the message source of email1.eml using Thunderbird in your VM. What the IP address listed as the X-Originating-Ip? 43.255.56.161

Task 5 - Email Body

Emails are sent as text only or formatted in HTML. HTML supports elements such as images, links, and styling. Most email clients show you the rendered content.

Viewing HTML Source Code: By viewing the raw source, we can clearly see how these HTML elements are structured behind the scenes, giving us a closer look at links, images, and other embedded content that may not be immediately visible in the rendered view.

Reconstructing Attachments: When we inspect the source, we can identify several important headers associated with the attachment:

- **Content-Type** indicates the file type `application/pdf`
- **Content-Disposition** specifies that the file is an attachment and includes its filename
- **Content-Transfer-Encoding** shows that the file is `base64` encoded

Answer the questions below

Open up the email2.txt file to view the source of an attachment. What is the Content-Type of the attachment? `application/pdf`

```
-----0917b1a36408bb427c440630707099
Content-Type: application/pdf; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
```

What is the name of the attachment from the previous question?
`mzmqpalgh.pdf`

Decode the base64 string using either a PDF converter (opens in new tab) or CyberChef (opens in new tab). What is the hidden flag value?
`THM{BENIGN_PDF_ATTACHMENT}`

Task 6 - Types of Phishing

- Spam(opens in new tab): Unsolicited bulk emails sent to a large number of recipients. A more malicious form of spam is often called malspam.
- Phishing(opens in new tab): Emails that impersonate a trusted entity to trick recipients into revealing sensitive information.

- Spear Phishing(opens in new tab): A targeted form of phishing aimed at a specific individual or organization, often using personalized information.
- Whaling(opens in new tab): A type of spear phishing that specifically targets high-level executives (CEO, CFO) to obtain sensitive data or financial access.
- Smishing(opens in new tab): Phishing attacks conducted via SMS or text messages, targeting users on mobile devices.
- Vishing(opens in new tab): Phishing attacks carried out through voice calls, where attackers use social engineering over the phone.

Anatomy of a Phishing Email

- **Spoofed From Address:** The sender's email is spoofed to appear as a trusted entity (`noreply@microsoft.com`)
- **Urgent Subject or Message:** The email creates a sense of urgency ("Your account will be locked in 24 hours")
- **Brand Impersonation:** The email is designed to mimic a legitimate organization (logos or colors matching a real company)
- **Grammar & Spelling Issues:** The message may contain errors, though with AI these are now less common (awkward phrasing or unnatural wording)
- **Generic Content:** The message lacks personalization ("Dear Customer" instead of your name)
- **Hidden or Shortened Links:** Hyperlinks may disguise their true destination (`bit.ly/secure-login`)
- **Malicious Attachments:** Attachments are included and disguised as legitimate files (`invoice.pdf.exe`)

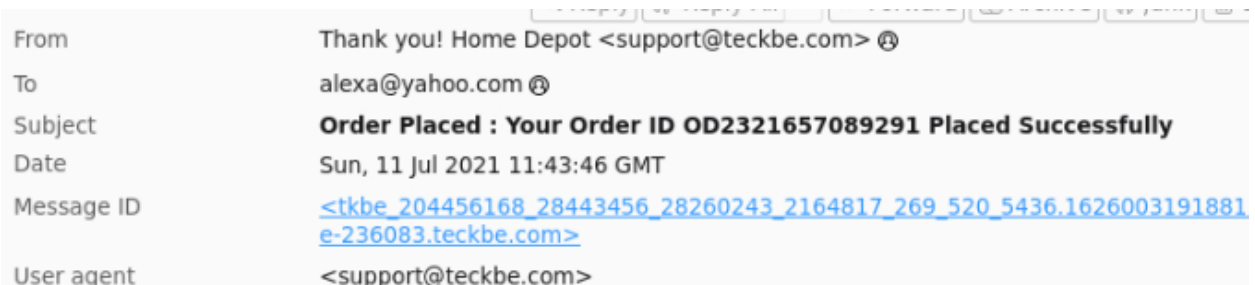
Safe Analysis: Hyperlinks(opens in new tab) and IP addresses(opens in new tab) should be **defanged**. Defanging makes URLs, domains, or email addresses unclickable to prevent accidental clicks that could lead to a security breach.

- Original URL: `http://www.suspiciousdomain.com`
- Defanged URL: `hxxp[://]www[.]suspiciousdomain[.]com`

Investigation: Let's put all of this knowledge to the test and analyze the email titled `email3.eml` within the virtual machine to answer the questions below.

Answer the questions below

Which reputable organization is being spoofed in this phishing attempt? Home Depot



The screenshot shows an email header with the following details:

- From:** Thank you! Home Depot <support@teckbe.com> @
- To:** alexa@yahoo.com @
- Subject:** Order Placed : Your Order ID OD2321657089291 Placed Successfully
- Date:** Sun, 11 Jul 2021 11:43:46 GMT
- Message ID:** <tkbe_204456168_28443456_28260243_2164817_269_520_5436.1626003191881e-236083.teckbe.com>
- User agent:** <support@teckbe.com>

What is the sender's email address? support@teckbe.com

Inspect the email message source. What is the defanged (opens in new tab) X-Originating-IP? 103[.]234[.]236[.]83

Continue analyzing the email message source. Which mail server generated the Authentication-Results header? atlas102.free.mail.gq1.yahoo.com

Task 7 - Conclusion

Examined common phishing techniques and applied your knowledge to analyze real-world examples, identifying attacker intent.

It's also important to understand Business Email Compromise (BEC), a type of attack where an adversary gains access to a legitimate internal email account and uses it to trick others into performing unauthorized or fraudulent actions.

Business Email Compromise (BEC) is an attack where an adversary gains access to a legitimate email account and uses that trusted identity to manipulate others into taking unauthorized actions, often involving money or sensitive data. Unlike noisy spam, BEC typically relies on trust and convincing business-like communication to evade suspicion.

2. Phishing Emails in Action

Task 1 - Introduction

This room focuses on the tactics attackers use to mirror legitimate communications. By analyzing real samples, you will learn to identify the subtle nuances that distinguish a routine notification from a sophisticated credential harvesting attempt.

Task 2 - Cancel Your Order

Phishing Techniques Used

- **Spoofed email address:** Mimicking a trusted service to gain immediate credibility
- **URL shortening:** Using redirection services to hide the true destination of a link
- **Branded HTML:** Impersonating legitimate corporate imagery to create a sense of authenticity

First Observations: Let's first look at the sample email header and take a few notes on our immediate observations.

1. **Attention-grabbing subject line:** The subject line uses a fake transaction to create a sense of urgency, prompting you to react in haste
2. **From address:** This is an immediate red flag as the sender details `service@paypal.com` do not match the actual address `gibberish@sultanbogor.com`
3. **To address:** This is an unusual email recipient address and not a normal Yahoo domain

Email Body Analysis: The email is designed to appear as a legitimate email from PayPal. There aren't any attachments associated with this email, and the only interactive element in this email is the `Cancel the order` button. Let's take a closer look.

Button Investigation: The `Cancel the order` button leads to the shortened URL. Because the attacker is using a URL shortening service, the final destination is obfuscated, making it impossible to verify the landing page at a glance.

Great online tools, such as [WhereGoes\(opens in new tab\)](#), that can be used to investigate shortened URLs without having to actually visit the destination.

Answer the questions below

Who is listed as the Merchant in the email body? Amazing Stuff

Merchant
Amazing Stuff
helpcenter@[REDACTED].com
899-552-[REDACTED]

Email address - confirmed

ppmxtrolling@[REDACTED].com

Task 3 - Track Your Package

Phishing Techniques Used

- **Spoofed email address:** Mimicking a trusted distribution center to gain immediate credibility
- **Pixel tracking:** invisible images to notify the sender when the email is opened
Embedding
- **Link manipulation:** Masking a malicious destination with a fraudulent tracking number

First Observations

1. **Subject line:** The subject line uses a fake tracking number to create a sense of urgency, prompting the recipient to click to see their package status
2. **From address:** This is an immediate red flag, as the display name **Distribution Center** does not match the actual sender address `contact@beginpro.club`
3. **Hyperlink:** The link in the email body matches the subject line, although we do not know where it directs to just yet

Hyperlink Tracking: Let's check out the source of the email message to get a closer look at the tracking number hyperlink from above. Here is an image file named `Tracking.png`. These trackers send information back to the spammer's server. There are several reasons spammers embed [tracking pixels](#)(opens in new

tab). (very small images) into their emails, and now we can understand why Yahoo automatically blocked the images in this email.

Answer the questions below

What root domain does the hyperlink in the above example point to? Be sure to defang the URL. devret[.]xyz

Task 4 - Download Document Here

In this task, we will analyze a phishing campaign(opens in new tab) that utilizes a multi-stage redirection chain to harvest user credentials. This sample demonstrates how attackers leverage the reputations of professional document-sharing services, such as OneDrive, Adobe, and Microsoft, to create a deceptive path that leads the victim to a fraudulent login portal.

Phishing Techniques Used

- **Artificial urgency:** Creating a narrow window for action to create a sense of urgency
- **Brand impersonation:** Layering trusted brands, like Microsoft and Adobe, to build a false sense of security
- **Link redirection:** Using a chain of URLs to hide the final malicious destination from basic email filters
- **Credential harvesting:** Deploying a fake login portal to capture and exfiltrate usernames and passwords

First Observations

1. **Send date:** The email was sent on Thursday, July 15th, 2021
2. **Expiration date:** A sense of urgency is introduced in this email. Notice that the link to download the fax document expires on the same day
3. **Download Document Here button:** There is an action to perform. In this case, a button to download the fax

Download Document Here: After clicking the `Download Document Here` button, the user is redirected to a landing page that mimics a legitimate OneDrive share.

Interacting with the buttons on this page triggers a second redirection to a site impersonating Adobe, though several critical red flags are apparent.

Logging In: In this example, the victim attempts to log in using Outlook. Even if they had entered valid credentials, the result would be the same: a generic error message. This happens because the page isn't actually authenticating the user to their mail service; it's simply a front used to send the credentials directly to the attacker's server.

Answer the questions below

The attacker deployed a fake portal to capture and exfiltrate user credentials.
What is this type of attack called? Credential Harvesting

Task 5 - Your Account Is on Hold

In this example, we will again examine an email claiming to be from a trusted, household brand that demands immediate action from the recipient. While previous cases may have relied on malicious links, this variant introduces a shady attachment. By masquerading as an official billing notification, the attacker attempts to bypass standard email filters and leverage the victim's sense of urgency.

Phishing Techniques Used

- **Spoofed email address:** The sender's display name is set to **Netllx billing** to appear legitimate
- **Sense of urgency:** Using a suspended account notification to pressure the victim into acting quickly
- **Brand impersonation:** Utilizing HTML templates and logos to mimic Netflix billing
- **Poor grammar and typos:** Noticeable misspellings of Netflix
- **Attachments:** Using a file attachment rather than a direct link to hide the malicious URL

First Observations

1. **Email subject:** The receiver's ID was suspended and must act quickly

2. **From address:** The display name does not match the user and domain
3. **Brand impersonation:** The email utilizes rendered HTML to impersonate Netflix

Email Body and Attachment Analysis

Taking a look at the email body, we can see that the user is informed that there is an issue with their billing information. In order to update their account, they must open the attached PDF file. The attachment contains an embedded link titled `Update Payment Account` which directs to a URL not associated with a legitimate Netflix domain. We will investigate this email in detail in the next room of this module, Phishing Analysis Tools. There are a couple other of points of interest worth noting.

1. The use of an atypical phone number format is a red flag
2. Using a legitimate Netflix help center domain to build a false sense of trust

Answer the questions below

What is the actual sender email address hidden behind the `Netllx billing` display name? z99@musacombi.online

Task 6 - Your Recent Purchase

In this example, we will analyze a phishing attempt that masquerades as a billing notification from a major service provider. Unlike previous tasks that relied on body text to lure the victim, this sample utilizes a completely blank email body, and relies solely on a suspicious attachment. We will examine how attackers use BCC fields and spoofed domains to hide the true recipient list while leveraging a sense of urgency to trick the user into opening a malicious file.

Phishing Techniques Used

- **Spoofed email address:** The sender's display name is set to **Apple Support**
- **Recipient is BCCed:** The victim is not directly sent the email
- **Urgency:** Relies on the use of **Action Required** and a fake purchase notification
- **Poor grammar and typos:** Noticeable spelling errors within the email header

- **Attachments:** The email contains a .dot(opens in new tab) file (Microsoft Word Template), which is an unusual format for a receipt

First Observations

1. **Email subject:** The recipient is told they must act quickly to resolve an unauthorized purchase, creating a false sense of urgency
2. **From address:** The display name, **Apple Support**, does not match the user and domain. There are also typos in the From and To addresses
3. **Blind Carbon Copy:** The recipient was not directly emailed, instead Blind Carbon Copied(opens in new tab) (BCC)

Analyzing the Attachment: The body of the email is completely blank, which is suspicious on its own. The only content present is an attachment in the form of a `.dot` file, so let's investigate further. When the user interacts with the large image embedded in the document, they are redirected to a phishing site. Although the URL includes familiar terms like **apps** and **ios** to appear legitimate, its excessive length and complexity are strong indicators of a malicious redirection attempt.

Answer the questions below

| What does the acronym BCC stand for? Blind Carbon Copy

| What is the file extension of the attachment? .dot

Task 7 - Scheduled Shipment

In this example, we analyze a phishing attempt that masquerades as a global shipping notification using spoofed addresses and branded HTML to appear legitimate. We will examine how the attacker funnels the victim toward a malicious Excel attachment designed to execute a hidden payload.

Phishing Techniques Used

- **Spoofed email address:** The sender's display name is set to `DHL Express`
- **Brand impersonation:** Utilizing HTML templates and logos to mimic DHL
- **Attachments:** An Excel document that triggers executable code upon opening

First Observations

1. **Email subject:** Gives the impression that DHL will be shipping a package
2. **From address:** The display name, **DHL Express**, does not match the user and domain
3. **Brand impersonation:** The HTML in the email body is designed to look like it is sent from DHL

Email Body and Attachment: While there isn't much depth to the email body, the meat of this phishing attempt lies in the attached `.xlsx` file. Opening the document reveals several glaring inconsistencies. First, the sender uses a German domain, the invoice is addressed to a city in India, yet the document content itself contains Mandarin. These conflicting geographical markers are classic red flags that should make us question their legitimacy. The document contains a single clickable link designed to move the attack to the next stage.

The Executable: When the link within the Excel document is clicked, it attempts to download and execute a malicious payload named `regasms.exe`. As seen in the screenshot, this execution results in a system error. While the error prevents the payload from running in this environment, it indicates the attacker's intent to execute code directly on the victim's machine. If successfully executed, the attacker could:

- **Establish Persistence:** Create a backdoor or scheduled task to maintain access after a reboot
- **Exfiltrate Data:** Steal sensitive files, credentials, or browser-stored passwords
- **Deploy Ransomware:** Encrypt the system and demand payment for recovery

Answer the questions below

What is the name of the executable that the Excel attachment attempts to run?
egasms.exe

Task 8 - Conclusion

In this room, you analyzed a series of phishing attempts and developed the skills needed to distinguish legitimate communications from malicious ones. By examining email headers, body content, links, and attachments, you learned how to identify common red flags such as spoofed senders, suspicious domains, and deceptive social engineering techniques.

3. Phishing Analysis Tools

Task 1 - Introduction

In this room, you will build on that foundation by learning about the tools that enable deeper analysis, then apply your skills by investigating three real-world phishing cases.

Task 2 - Identifying Artifacts

When analyzing a suspicious or malicious email, your first goal is to collect key artifacts that can help determine its legitimacy and intent. These artifacts provide the foundation for deeper investigation, such as reputation checks, threat intelligence lookups, and behavioral analysis.

Header Artifacts: When you begin your analysis with the email header, you should take note of the following points:

- **Sender email address:** Where did the email originate from?
- **Sender IP address:** What is the source IP, and what does a reverse lookup reveal?
- **Email subject line:** Does it contain urgency or a call to action?
- **Recipient email address:** Who is the intended recipient (To/CC/BCC)?
- **Reply-To email address:** Where are responses being directed?
- **Date and time:** When was the email sent?

Body Analysis: Next comes the email body, which has its own set of artifacts to be aware of:

- **URLs and hyperlinks:** Identify all links and expand shortened URLs to reveal their true destination
- **Attachment name(s):** What files are included, and do their names or extensions appear suspicious
- **Attachment hash:** Generate a hash value for threat intelligence lookups

Task 3 - Email Header Analysis

Mail Header Analysis: [Messageheader\(opens in new tab\)](#), part of the Google Admin Toolbox, helps analyze email headers. By simply pasting the full header into the tool, you can quickly extract key details such as the sender's IP address, routing path, and potential misconfigurations.

Another great tool, [Message Header Analyzer\(opens in new tab\)](#), can perform the same type of analysis. Check it out in the screenshot below.

IP and URL Reputation Analysis: [IPinfo\(opens in new tab\)](#) is a simple and effective tool for gathering information about an IP address. By entering an IP, you can quickly view details such as its geographic location and associated organization. This helps analysts determine whether an IP is potentially malicious.

[URLScan.io\(opens in new tab\)](#) is a tool that enables analysts to safely investigate websites without visiting them directly. By submitting a URL, the service simulates a real user browsing session and records all activity generated by the page. It also captures a screenshot of the site and provides insight into its behavior, helping analysts quickly identify suspicious or potentially malicious content.

Talos [IP & Domain Reputation Center \(opens in new tab\)](#) is a threat intelligence tool from Cisco that enables analysts to assess the reputation of IP addresses, domains, and networks. By submitting an indicator, you can quickly assess whether it has been associated with malicious activity and view its classification.

Answer the questions below

According to the Messageheader analysis shown in this task, what is the SPF result for the email? pass

Subject:	Lose weight with Medvi - or get your money back
SPF:	pass with IP 212.81.58.178 Learn more

Task 4 - Email Body Analysis

Mail Body Analysis: Determining the destination of a link within an email can be as easy as right-clicking the link and selecting [Copy link address](#) (the option's name may vary depending on your browser or email provider). From here, you can safely assess the URL without actually following it to the destination page.

Another effective way to identify URLs in an email is to use a [URL extraction tool\(opens in new tab\)](#). These tools let you paste raw email content and automatically parse all embedded links, saving time and reducing the risk of missing hidden or obfuscated URLs. Tools like [CyberChef\(opens in new tab\)](#) can also perform this function, making them a versatile option for email analysis.

Email Attachments: If the email you are investigating contains an attachment, it may be tempting to download it directly using your email client. However, attachments should only be downloaded in a controlled environment, such as a lab machine or sandbox, to reduce the risk of accidental execution. Once safely obtained, you can use tools like the `sha256sum` command in a Linux environment to generate a hash value for further analysis and reputation checks.

```
user@tryhackme$ sha256sum shady_attachment.pdf
025ba9ce4a2118a9ca7b115c8869ff73bc16bad3732ba359cef1e60ad8f96
1f9 shady_attachment.pdf
```

Once you've obtained the hash value, several sites can safely assist with analyzing the attached file. Let's return to Talos [IP & Domain Reputation Center\(opens in new tab\)](#) from the previous task and analyze the hash value from above. In this case, the file is labeled as *Phishing*, *Malicious*, and *Spam*, indicating that this file is likely harmful.

[VirusTotal\(opens in new tab\)](#) is a widely used tool that allows analysts to check the reputation of files, URLs, IP addresses, and domains using data from dozens of security vendors. By submitting a file or indicator, you can quickly determine whether it has been flagged as malicious and review detailed detection results. VirusTotal also allows users to upload files and submit URLs for analysis, making it a powerful resource for investigating suspicious artifacts.

Answer the questions below

What command can you use in a Linux environment to obtain the SHA256 hash value of an attachment? sha256sum

Task 5 - Malware Sandboxes

ANYRUN: [ANY.RUN\(opens in new tab\)](#) is an interactive malware sandbox that allows analysts to safely execute and observe suspicious files and URLs in real

time. Unlike traditional sandboxes, it provides a hands-on experience in which you can interact with the environment, monitor processes, view network activity, and analyze system changes as they happen. This makes it a powerful tool for understanding how malware behaves and identifying key indicators of compromise in a controlled setting.

Hybrid Analysis: Similar to the tool above, [Hybrid Analysis\(opens in new tab\)](#) is a free malware analysis sandbox that allows analysts to upload and examine suspicious files in a controlled environment. It provides detailed insights into file behavior, including system changes, network activity, and indicators of compromise, helping analysts better understand the potential impact of a malicious file.

JOESandbox: JOESecurity created the [JOESandbox\(opens in new tab\)](#) for advanced malware analysis. It performs both static and dynamic analysis on suspicious files and URLs. It generates comprehensive reports that highlight behavior, indicators of compromise, and threat classifications.

Task 6 - Using PhishTool

A powerful platform that streamlines phishing investigations is [PhishTool\(opens in new tab\)](#). It is designed for security professionals across multiple disciplines. PhishTool automates much of the manual work involved in analyzing suspicious emails. Whether you are a SOC analyst triaging user-reported messages, a threat intelligence analyst collecting indicators, or a researcher investigating phishing kits, PhishTool brings everything together in one place. By combining threat intelligence, OSINT, email metadata, and automated analysis workflows, PhishTool provides a centralized view of phishing activity, helping you quickly identify malicious intent and extract valuable indicators of compromise.

Identifying Artifacts: Upon uploading an email to PhishTool, you are presented with many of the valuable artifacts that we discussed in the second task. On the right-hand side, the tool provides the rendered HTML view, similar to what you'd see in your inbox, the raw HTML, and also the message source. Pretty useful!

Further Analysis: By navigating the tabs across the top of PhishTool, you can analyze key components of the email, including authentication results, transmission paths, and any embedded URLs. If the email contains attachments,

they can also be reviewed and analyzed directly within the platform, giving you a comprehensive view of the message in one place.

One of PhishTool's standout features is its integration with VirusTotal, allowing you to view reputation and detection results without leaving the tool. This seamless integration helps speed up investigations by bringing external intelligence directly into your workflow.

Resolving the Case: Once your analysis is complete, PhishTool allows you to formally document your findings. As shown below, the email can be marked as malicious, with key artifacts, such as sender addresses, originating IP, and embedded URLs, to be flagged. You can then add investigation notes and click **Resolve**, mirroring the documentation and case closure process used in a real SOC environment.

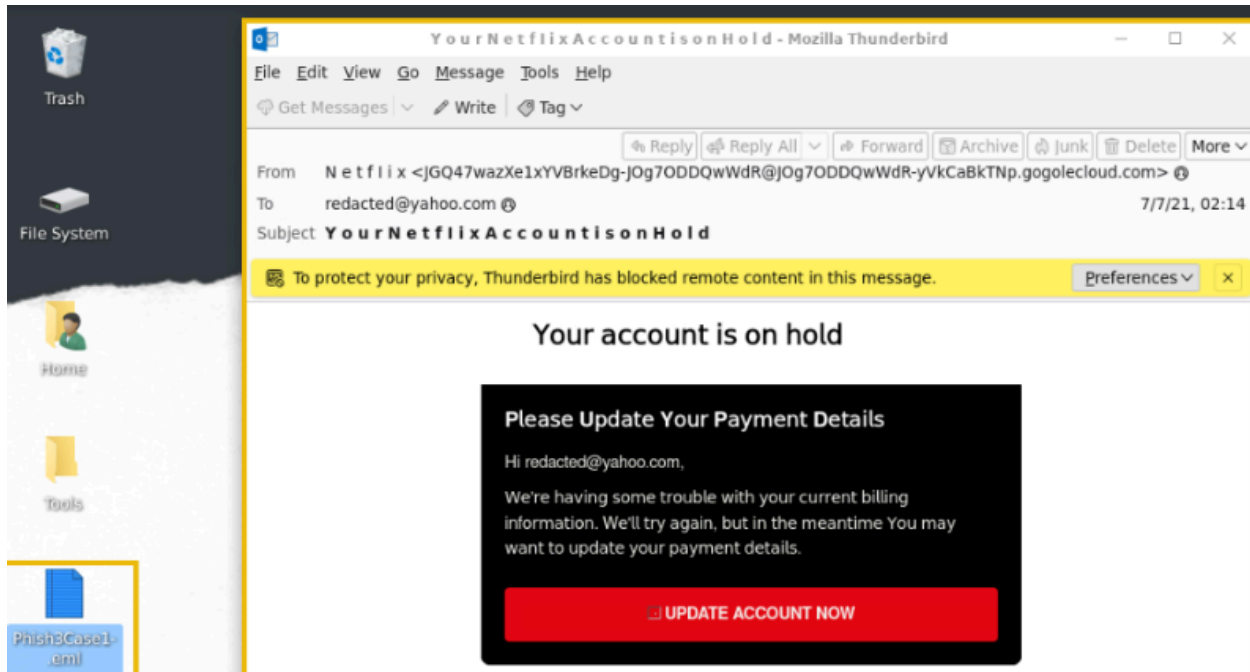
Answer the questions below

According to the VirusTotal analysis from above, which vendor categorized the URLs as phishing? SafeToOpen

Task 7 - Your Account Is on Hold

In this scenario, you are a level 1 SOC analyst. As the first line of defense, you have to identify phishing and spam emails reported by end users. In the following tasks, you will step into that role and analyze multiple suspicious emails that have been escalated by coworkers. Your objective is to carefully review each email, extract key indicators, and identify any signs of malicious activity. The findings you uncover will help your team develop detection rules to prevent similar threats from reaching other users in the future. Once the environment has loaded in the split-screen view, navigate to the desktop and open the file `Phish3Case1.eml`. From there, begin your investigation by reviewing the email header and body, and apply the analysis techniques covered throughout this room.

Note: The domains, URLs, and IP addresses referenced in this task have hosted real malicious content and may still pose a risk. Do not access or interact with them outside of a controlled lab environment.



Answer the questions below

What reputable brand is this email tailored to impersonate? Netflix

Based on the email headers, who is the intended recipient of this message?
redacted@yahoo.com

In Thunderbird mail use View → Message Source. What is the Received: from IP address? 10.197.37.234

Check out the Return-Path field in the message source. What would you consider a domain of interest based on this field? etekno.xyz

Investigate the UPDATE ACCOUNT NOW button. What is the shortened URL?
<https://t.co/yuxfZm8KPg?amp=1>

```

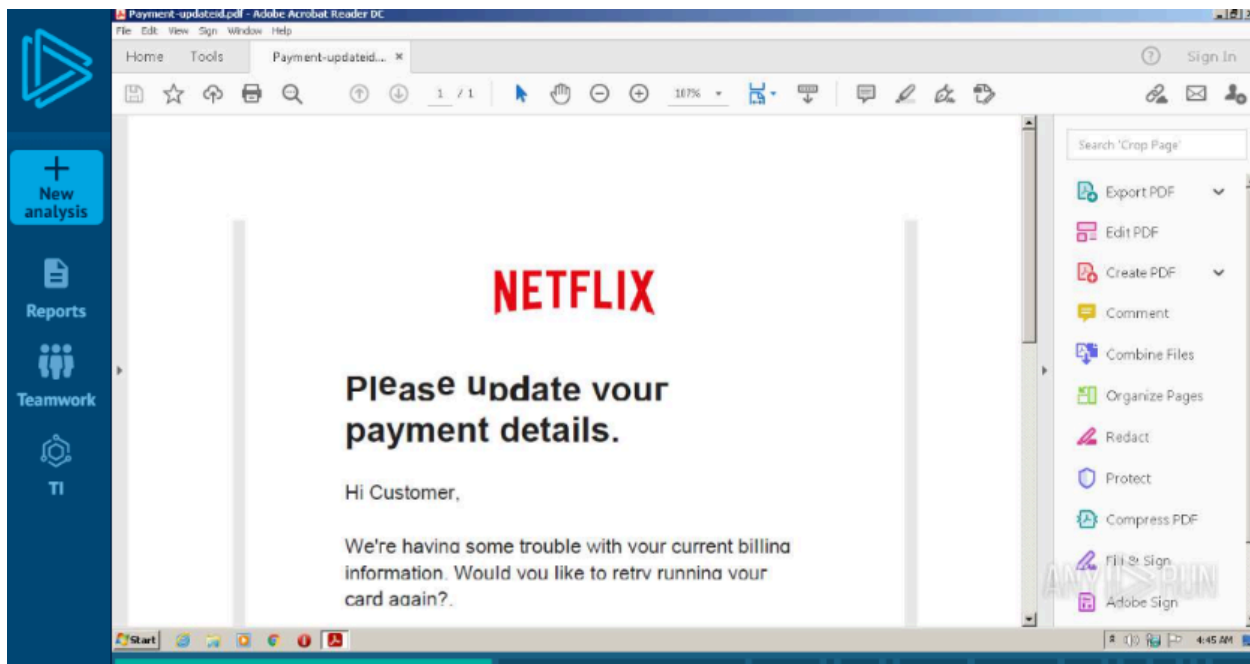
Received: from 10.197.37.234
  by atlas105.free.mail.bfl.yahoo.com with HTTPS; Wed, 7 Jul 2021 02:14:46 +0000
Return-Path: <postmaster@etekno.xyz>
X-Originating-Ip: [209.85.167.226]
Received-SPF: none (domain of etekno.xyz does not designate permitted sender hosts)
Authentication-Results: atlas105.free.mail.bfl.yahoo.com;
  dkim=unknown;
  spf=none smtp.mailfrom=etekno.xyz;
  dmarc=unknown header.from=J0g70DDQwWdR-yVkJCaBkTNP.gogolecloud.com;
X-Apparently-To: redacted@yahoo.com; Wed, 7 Jul 2021 02:14:47 +0000
X-YMailISG: soSDWIIWLDuoG8NhyrHXr7QH4K4775ng5KvMq.0Ur7XVVwU
  Be3WPYvUM8wM0n0esjRJB1FL8aYJlqdiZ9E90kXzWdWdt0YQu60W8AYAEh2
  wVHhZe98VYCjMHeR0pIec7.YYXLSVz9FiWUea09lCEmQ0LmI2ELSeQMPxQyi
  2qZtWwPhHVUbjxbMIRQh3teEA3AlGt7wRZ_j_HwdkS1nnSaFbsnrKZBFw0W1
  AmDq.IFtpSufP_Qj3jDDUR3c5x5E9ZjghaA0Udfe4HQ9H_Dc47XAqD.MXAPd
  Vy5UXg9t0N8lSm4d0P72lAIQ1YkMR04c9LQ3LeP9f1sqycImfT4M_EO.ChI
  AfCaG15Kxytf0GMVVj5Nq..sCJS0bLHY3ZHD8.ddKlJe34v54EABsTv9g8XI
  aFatYydf0MHgWeJ3owQNYH5tT10vzXS33AXecgKPLY0XhACgm0XhNXH5ot6b
  YfBvWl_ViqX5nEEL3Igt1KQ2Zvsih6dqNPfdK5NHx990d1z82V_Yn2scnqvE
  1XnxggaQu7pEEgP2N768_DQc_ES7_UpSiTTmkXHMx5T3Eib4dvDhv.YKXu71
  GDJFaR60VYUjTmHE44FxdVynvKHs_Z2avfKM_m2LftlonkTeScmZRBefstPC
  CkXLPQowSxVbHbFjPEZXPu4UA9L1Cs_IlnHa7GbIcgx4.Mix2lsMTw.ihbd
  68qMFXSUXxiQUOKut7Mw5qJZvYppq8SYaoi0tYyqBihqQeATq0Mj9sfxPw5o
  uRmyXBx6PHNbpwrfjnoxpr_gMKPzy55dh07pCD1DvDwKRNbZWgCwCpSeoq.f
  LUK5js1TGLW7e28G4nKHftU10yt4fnyM8FbEWS8hZNXBSY77wyAhHH1i5HI9
  XoiPc3nb_Ma50sVUBti6MNH2ilqJehZ2AACN4zZVFbDT9hdPjqt36A2gDlu2
  pAw7uRhduPd553t51qVBvKYTpCDaGzFvWiBVXXu4v3ZYg_ykwbtsXLPZ39j
  iQXKjJtRPQaLzbMXJHlenJ4Cfqt05ADm67ukSrflyPQIYplN3a4KfYsbn33
  50Mhkpr5tuQyX0qMukzZevD83XwhbPZ7SiQpjm7H0gvA--
Received: from 209.85.167.226 (EHLO mail-oil-f226.google.com)
  by 10.197.37.234 with SMTPs
  (version=TLS1_2 cipher=TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256);
  Wed, 07 Jul 2021 02:14:46 +0000
Received: by mail-oil-f226.google.com with SMTP id l21sol661147oig.3
  for <redacted@yahoo.com>; Tue, 06 Jul 2021 19:14:46 -0700 (PDT)
X-Google-DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
  d=1e100.net; s=20161025;
  h=x-gm-message-state:message-id:date:to:from:subject:mime-version;
  bh=HLZRRPnbarLRjncKEGgNtsm2Tn4k0daz6jLRP02QPM=;
  b=hPZp80yziaNDXDeDdUiRm56hX+p7ZmlIFI2Plc4XmJwbpsI28MZy3oHw3ko+30eNa
  3oDECpmIEfDrvi9AeqrzHrJL1aTe4mhJHqvaf2JlB6g/t19mjtyIK3EN+xy6GQs1qsfh
  1Zi0TkwVUIttCXykeym6FbJuQ9k78n+/VX1YR40DT/KoFN1CGXjt1ZOKIDHNuXxAbpK
  ZMaPsIFij2BPQtJaJC6/fcYsVP7d885WIO3HMgAxBAJlZyU4PTIMXZMN/1TkT6ESC/w/
  QooM1fMPC0whY8ibYAJZRgTrqyS/N338JinwhV/utBxp5Cu+bVlRj0B2u0LU6mW0jLfo
  4cvg==

```

Task 8 - Update Payment Details

In this task, you will investigate a malicious attachment using **ANYRUN**. This is a suspected phishing email masquerading as a Netflix payment update notification. Using the [provided sandbox \(opens in new tab\)](#), review the file's behavior, network activity, and any indicators of compromise. Pay close attention to how the attachment executes and interacts with the system.

Note: The domains, URLs, and IP addresses referenced in this task have hosted real malicious content and may still pose a risk. Do not access or interact with them outside of a controlled lab environment.



Answer the questions below

How does ANYRUN classify this suspected phishing email? Suspicious activity

What is the name of the PDF attachment? Payment-updateid.pdf

Investigate the email attachment. What is the SHA256 hash of the PDF file?
cc6f1a04b10bcb168aeec8d870b97bd7c20fc161e8310b5bce1af8ed420e2c24

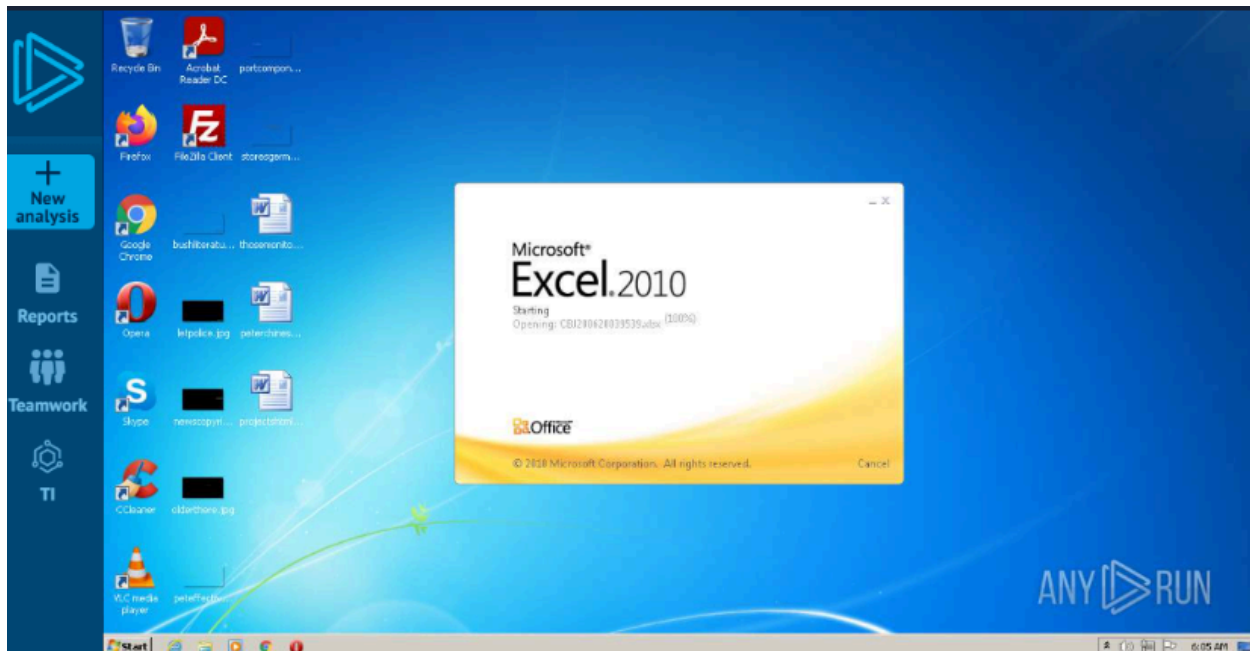
Check out the ANYRUN text report on the phishing email. Which IP address associated with the process AcroRd32.exe is flagged as malicious? 2.16.107.24

Continue investigating the text report. Which Windows process is classed as Potentially Bad Traffic? svchost.exe

Task 9 - Excel Executable

In this task, you will continue your investigation using **ANYRUN**, focusing on a different sandbox analysis(opens in new tab) of a suspected phishing attachment. Review the execution results to identify notable behaviors, including process activity, network connections, and any indicators of compromise. Use these insights to better understand how the file operates and what makes it malicious.

Note: The domains, URLs, and IP addresses referenced in this task have hosted real malicious content and may still pose a risk. Do not access or interact with them outside of a controlled lab environment.



Answer the questions below

- | How does ANYRUN classify the .xlsx attachment? Malicious activity
- | What is the file name of the Excel attachment? CBJ200620039539.xlsx
- | Investigate the Excel attachment. What is the SHA256 hash value?
5f94a66e0ce78d17afc2dd27fc17b44b3ffc13ac5f42d3ad6a5dcfb36715f3eb
- | Check out the ANYRUN text report. What IP address is associated with the malicious domain biz9holdings.com? 204.11.56.48
- | Which other domain is classified as malicious? findresults.site
- | What vulnerability does this malicious attachment attempt to exploit? CVE-2017-11882

Task 10 - Conclusion

In this room, you developed a structured approach to phishing analysis by learning what information should be collected during an investigation and how to effectively examine suspicious emails.

4. Phishing Prevention

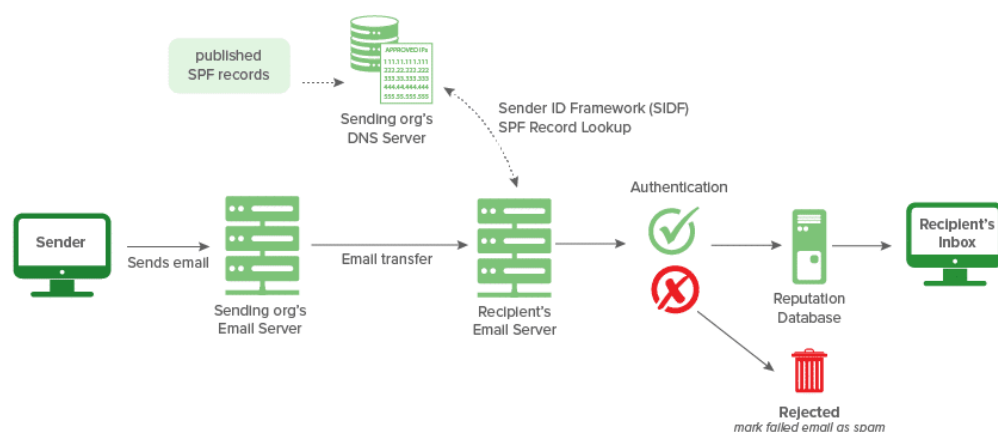
Task 1 - Introduction

Phishing remains one of the most common and effective ways for attackers to gain initial access to target systems. To counter this, defenders can deploy a variety of tools and controls designed to protect users from malicious emails.

Task 2 - Sender Policy Framework (SPF)

Dmarcian, a platform dedicated to helping organizations protect email domains from phishing, defines the **Sender Policy Framework (SPF)** ([SPF\(opens in new tab\)](#)) as follows:

"Sender Policy Framework (SPF) is used to authenticate the sender of an email. With an SPF record in place, Internet Service Providers can verify that a mail server is authorized to send email for a specific domain. An SPF record is a DNS TXT record containing a list of the IP addresses that are allowed to send email on behalf of your domain."



So, in essence, when an email is sent, the receiving mail server checks the domain's SPF record to verify whether the sending server is authorized to send messages on behalf of that domain. The delivery of the email (intended action) is based on the result of the SPF record verification.

Verification Result	Intended Action
Pass, Neutral, None	Accept (Allow and process the email)
SoftFail, PermError	Flag (Mark as suspicious but allow)
Fail, TempError	Reject (Immediately discard the email)

SPF Records: Let's take a look at a sample SPF record and break down its format. Further information on SPF Record Syntax can be found [here\(opens in new tab\)](#).

```
v=spf1 ip4:127.0.0.1 include:_spf.google.com -all
```

- `v=spf1` Signifies the start of the SPF record
- `ip4:127.0.0.1` Specifies which IP can send mail (IPv4 in this case)
- `include:_spf.google.com` Specifies which domain can send mail
- `all` Non-authorized emails will be rejected

Tools: The **[SPF Surveyor\(opens in new tab\)](#)** tool from dmarcian enables us to gain a visual look at DNS records. It also helps ensure the record uses the correct syntax.

You may notice that no IP addresses are visibly present in the main record, but three domains are listed. In this case, all IP addresses authorized by the domains will be recognized as legitimate senders.

- `_spf.google.com`
- `email.chargebee.com`
- `7168674.spf05.hubspotemail.net`

Google Admin Toolbox [Messageheader\(opens in new tab\)](#) allows you to analyze delivery details using an email's full header. It shows various record results, including SPF. Check out the example below, which shows the SPF record as `softfail with IP Unknown!`. A `SoftFail` means the sending mail server is not listed as an authorized sender, but the receiving server will still accept the email and flag it as suspicious. In this case, the sending IP address could not be verified.

MessageId	20251001123456.abc123@mail.attacker.thm
Created at:	10/1/2025, 8:34:55 PM GMT+8 (Delivered after 1 sec)
From:	"Acme Billing" <billing@example.com>
To:	victim@receiver.thm
Subject:	Invoice #12345 – Action Required
SPF:	softfail with IP Unknown!

Answer the questions below

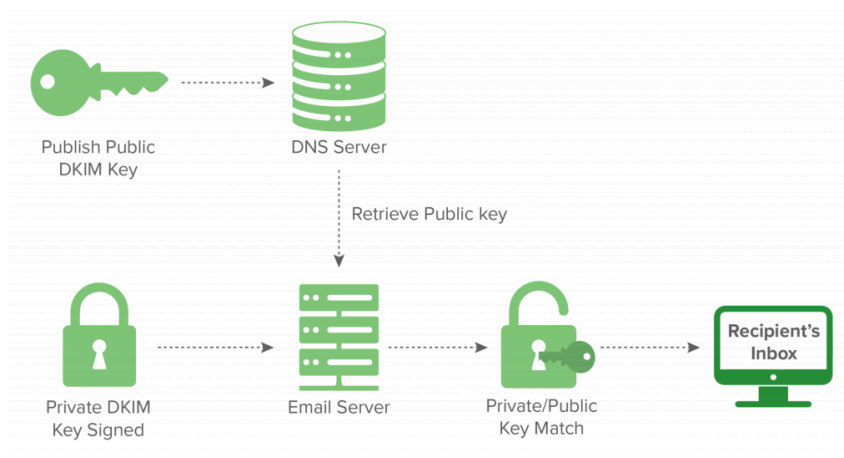
Based on TryHackMe's SPF record above, how many domains are authorized to send email on its behalf? 3

What is the intended action of an email that returns a SoftFail verification result? Flag

Task 3 - DomainKeys Identified Mail (DKIM)

DomainKeys Identified Mail (DKIM(opens in new tab)) is defined as follows:

"DKIM stands for DomainKeys Identified Mail and is used for the authentication of an email that's being sent. Like SPF, DKIM is an open standard for email authentication that is used for DMARC alignment. A DKIM record exists in the DNS, but it is more complex than SPF. DKIM's advantage is that it can survive forwarding, which makes it superior to SPF and a foundation for securing your email."



Let's break it down. When an email is sent, the sending mail server uses a private key to add a digital signature to the email. The receiving server retrieves the public key from the domain's DKIM record to verify that the message truly came from the domain. If the signature matches, the email is authentic; otherwise, it may be flagged or rejected.

Here is a sample DKIM record, along with its components.

```
v=DKIM1; k=rsa; p=<public_key>
```

- **v=DKIM1** Specifies the version of DKIM being used (optional)
- **k=rsa** The key type. The RSA encryption algorithm is standard
- **p=** This is the public key that will be matched to the private key to verify the DKIM signature

Note: DKIM record formats vary and may include other tags depending on the mail provider or implementation.

Dmarcian has some great [resources](#) if you wish to learn further about DKIM. You can also check out their [DKIM Record Checker](#) and [Validator](#).

Sample Spam Email Header: The image below is a snippet of an email header that was marked as spam with a DKIM result of **permerror**, indicating a permanent failure in DKIM verification. This could be the result of an invalid signature, a missing or incorrect DNS record, a forwarding server making a modification, or a misconfiguration in DKIM setup.

```
Received: from relay.fakevendor-mail.net (203-0-113-94.isp.example.net. [203.0.113.94])
  by mx.traininglab.com with ESMTPS id lab123456789abc.987.2025.10.06.10.42.21
  for <learner@traininglab.com>
  (version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
  Mon, 06 Oct 2025 10:42:21 +0000
Received-SPF: pass (traininglab.com: domain of return@marketing-notify.appmailer.securemail.example
  designates 203.0.113.94 as permitted sender) client-ip=203.0.113.94;
Authentication-Results: mx.traininglab.com;
  dkim=permerror (no key for signature) header.i=@alerts.securemail.example header.s=default;
  spf=pass (traininglab.com: domain of return@marketing-notify.appmailer.securemail.example
  designates 203.0.113.94 as permitted sender) smtp.mailfrom=Return@marketing-
  notify.appmailer.securemail.example;
  dmarc=fail (p=none dis=none) header.from=securemail.example
```

Answer the questions below

Based on the sample header above, what is the reason for the permerror? no key for signature

Task 4 - Domain-Based Message Authentication, Reporting, and Conformance (DMARC)

Domain-Based Message Authentication, Reporting, and Conformance (DMARC)([opens in new tab](#)) is defined as follows:

"DMARC, an open source standard, uses a concept called alignment to tie the result of two other open source standards, SPF (a published list of servers that are authorized to send email on behalf of a domain) and DKIM (a tamper-evident domain seal associated with a piece of email), to the content of an email."

This means that DMARC ensures the sender's domain matches the domains verified by SPF and DKIM. If the alignment fails, DMARC instructs the recipient server on how to handle the email based on a policy specified in the record.

DMARC Records: Here is a breakdown of a DMARC record and its components.

```
v=DMARC1; p=quarantine; rua=mailto:postmaster@website.com
```

- **v=DMARC1** : The version of DMARC (required)
- **p=quarantine** The DMARC policy (quarantine = move to the spam folder)
- **rua=mailto:postmaster@website.com** An optional tag. In this case, aggregate reports will be sent to the email specified

Domain Checker: Another great [tool](#)([opens in new tab](#)) by dmarcian that inspects DMARC, SPF, and DKIM records to identify any issues. Let's try it out on [microsoft.com](#).

In the screenshot below, you can see that [microsoft.com](#) passed all the checks. Clicking the details will allow you to examine each record and policy more closely. As shown in the record below, all emails that fail the DMARC check will be rejected based on the **p=reject** policy tag.

Well done! You have a valid DMARC record that provides visibility into the entirety of your email program(s) and helps ensure you meet email sending best practices. Your domain takes full advantage of the domain protections afforded by DMARC.

The checks performed here are similar to those done by mailbox providers such as Google, Yahoo and Microsoft. DMARC, SPF and DKIM records live in your domain's DNS and are used by mailbox providers to separate legitimate email from abuse. Based on your strict DMARC policy, mailbox receivers can reliably identify and block phishing, spoofing and unauthorized use of your domain.

GET STARTED

✓ DMARC

Your domain has a valid DMARC record and your DMARC policy will prevent abuse of your domain by phishers and spammers.

— Details

```
v=DMARC1; p=reject; pct=100; rua=mailto:itex-rua@microsoft.com; ruf=mailto:itex-ruf@microsoft.com; fo=1
```

To understand and fix the specific errors, use our [DMARC Inspector](#).

Answer the questions below

Which DMARC policy provides the greatest amount of protection by blocking emails that fail the DMARC check? p=reject

Task 5 - Secure/Multipurpose Internet Mail Extensions (S/MIME)

Secure/Multipurpose Internet Mail Extensions (S/MIME) ([opens in new tab](#)) is a standard protocol for sending digitally signed and encrypted messages. It is based on public key cryptography, where the private key is never shared and the public key can be distributed openly. The two main components and security features of S/MIME are:

Digital Signature: The sender signs the message with their private key, the recipient verifies the sender's identity using the sender's public key. This security feature provides:

- **Authentication:** Confirms the sender's identity through their digital certificate
- **Non-repudiation:** Ensures the sender cannot deny sending the message
- **Data Integrity:** Detects any changes to the message after it's signed

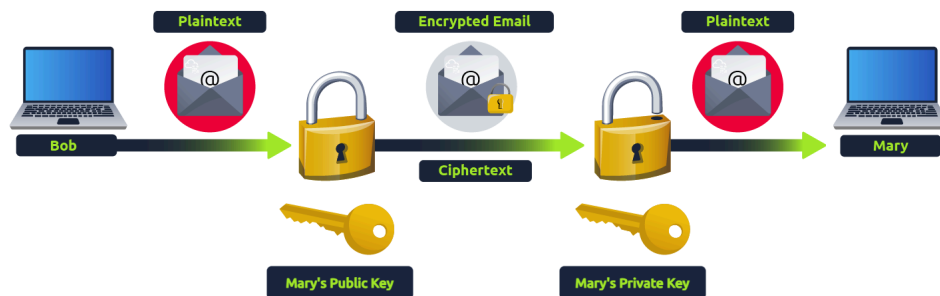
Encryption: The sender encrypts the message using the recipient's public key, allowing only the recipient to decrypt it with their private key. This security feature provides:

- **Confidentiality:** Keeps the content private and readable only by the intended recipient

S/MIME Example

- Bob wishes to securely send the email with S/MIME to Mary
- Bob creates a digital certificate to generate the **Digital Signature**
- Bob "signs" the email message with his private key (**Digital Signature**)
- Bob openly shares his public key with Mary (**Digital Signature**)
- Bob also asks the public key of Mary to encrypt the email (**Encryption**)
- Mary verifies Bob's message with Bob's public key (**Digital Signature**)
- Mary decrypts the received message with her private key (**Encryption**)
- To send a reply email, Mary performs the same procedure from the start
- Both Bob and Mary will now have each other's certificates for future correspondence

Check out the graphic below for a visual representation of how public key cryptography works.



Answer the questions below

Which S/MIME component ensures that only the intended recipient can read the contents of an email message? Encryption

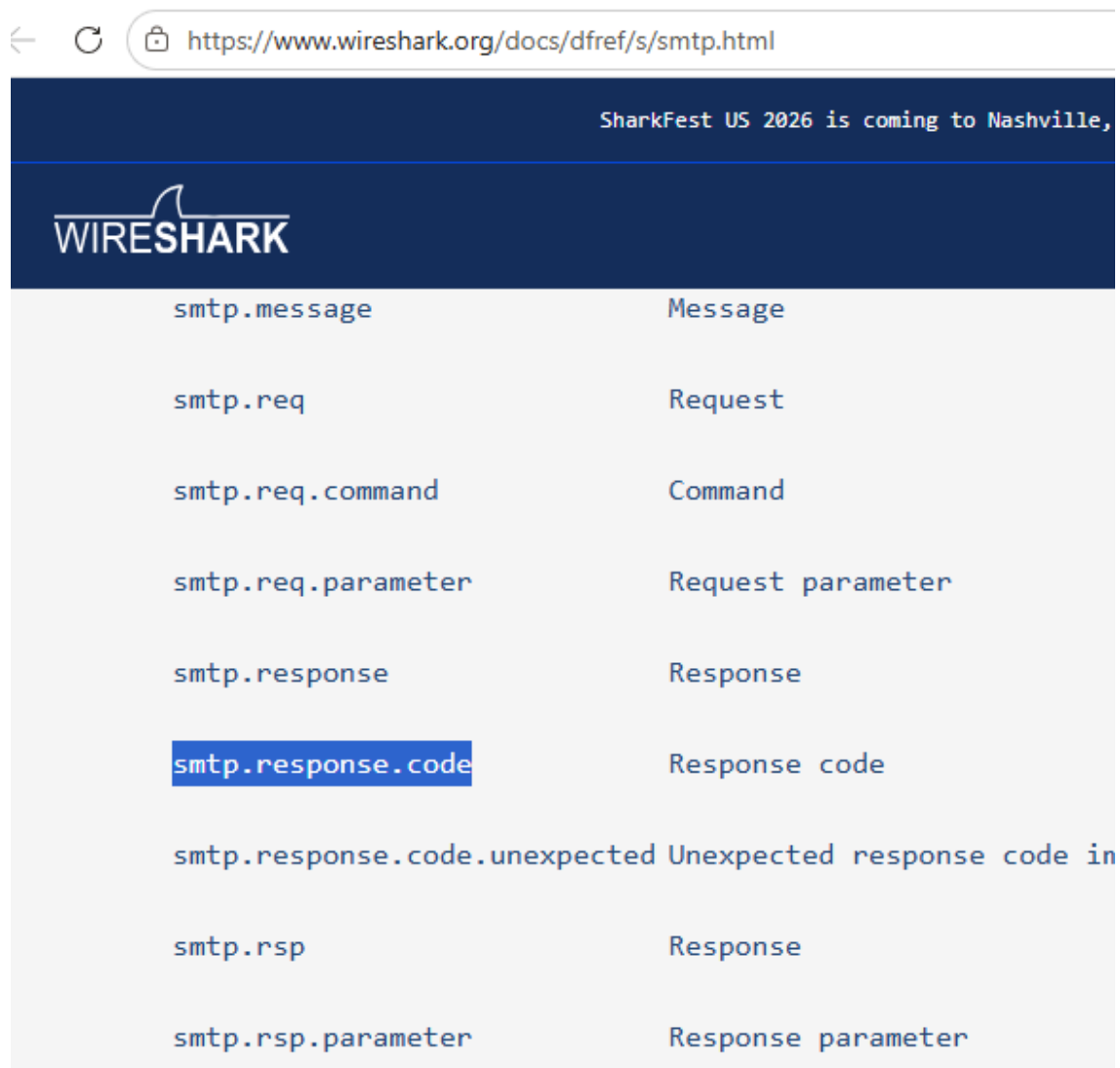
Task 6 - Analyzing SMTP Responses

In this task, you will analyze a PCAP file with SMTP traffic. Some familiarity with traffic analysis using Wireshark will be helpful, as well as knowledge

of [SMTP Wireshark filters](#)(opens in new tab) and [status codes](#)(opens in new tab). Go ahead and deploy the machine attached to this task. It will appear in the split-screen view when it's ready. Then, open the `traffic.pcap` file on the Desktop to begin your examination.

Answer the questions below

Which Wireshark filter can you use to narrow down your results based on SMTP response codes? `smtp.response.code`



The screenshot shows a web browser window with the URL `https://www.wireshark.org/docs/dfref/s/smtp.html`. The page header includes the Wireshark logo and a banner for "SharkFest US 2026 is coming to Nashville,". Below the header is a table of SMTP filters. The filter `smtp.response.code` is highlighted with a blue background.

Filter	Description
<code>smtp.message</code>	Message
<code>smtp.req</code>	Request
<code>smtp.req.command</code>	Command
<code>smtp.req.parameter</code>	Request parameter
<code>smtp.response</code>	Response
<code>smtp.response.code</code>	Response code
<code>smtp.response.code.unexpected</code>	Unexpected response code in
<code>smtp.rsp</code>	Response
<code>smtp.rsp.parameter</code>	Response parameter

How many packets in the capture contain the SMTP response code 220 Service ready? 19

smtp.response.code == 220					
No.	Time	Source	Destination	Protocol	Length Info
150	146.508060	216.97.88.9	10.12.19.101	SMTP	132 S: 220 unicode.org ESMTP S
191	184.709525	173.199.147.120	10.12.19.101	SMTP	229 S: 220-host.oclahost.com E
203	199.858597	173.199.147.120	10.12.19.101	SMTP	274 S: 220-host.oclahost.com E
217	215.086064	173.199.147.120	10.12.19.101	SMTP	274 S: 220-host.oclahost.com E
255	275.774157	173.194.66.27	10.12.19.101	SMTP	106 S: 220 mx.google.com ESMTP
386	276.682635	173.194.66.27	10.12.19.101	SMTP	106 S: 220 mx.google.com ESMTP
576	278.728073	173.194.66.27	10.12.19.101	SMTP	106 S: 220 mx.google.com ESMTP
698	280.331519	31.7.4.183	10.12.19.101	SMTP	125 S: 220 tc1.shockmedia.nl E
744	288.817795	74.125.138.27	10.12.19.101	SMTP	112 S: 220 mx.google.com ESMTP
753	289.238050	65.102.237.118	10.12.19.101	SMTP	117 S: 220 sudo.ws ESMTP spamd
909	300.500526	173.194.66.27	10.12.19.101	SMTP	104 S: 220 mx.google.com ESMTP
1032	312.545910	64.233.180.27	10.12.19.101	SMTP	107 S: 220 mx.google.com ESMTP
1153	324.618573	173.239.79.204	10.12.19.101	SMTP	121 S: 220 mail2.eff.org ESMTP
1206	349.166346	82.103.137.214	10.12.19.101	SMTP	130 S: 220 mail2.information.t
1333	360.869461	63.245.210.103	10.12.19.101	SMTP	101 S: 220 smtp1.mail.mdc2.moz
1390	384.041480	65.102.237.118	10.12.19.101	SMTP	117 S: 220 sudo.ws ESMTP spamd
1421	395.022264	65.102.237.118	10.12.19.101	SMTP	110 S: 220 sudo.ws ESMTP spamd

Frame 150: 132 bytes on wire (1056 bits), 132 bytes captured (1056 bits)
 Ethernet II, Src: Netgear_b6:93:f1 (20:e5:2a:b6:93:f1), Dst: HewlettP_1c:47:ae (00:08:02:1c:47:ae)
 Internet Protocol Version 4, Src: 216.97.88.9, Dst: 10.12.19.101
 Transmission Control Protocol, Src Port: 25, Dst Port: 49171, Seq: 1, Ack: 1, Len: 78
 Simple Mail Transfer Protocol
 Response: 220 unicode.org ESMTP Sendmail Secure/Rahid: Wed. 19 Dec 2018 10:17:29 -0600\r\n

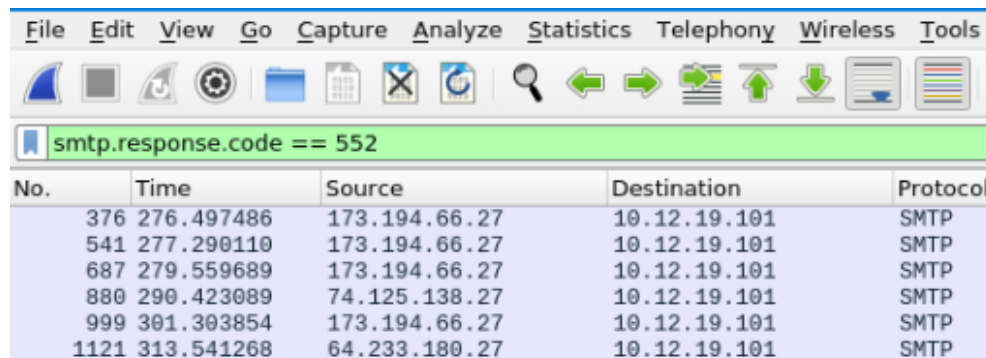
One SMTP response indicates that an email was blocked by spamhaus.org.
 What response code did the server return? 553

smtp.response.code == 553					
No.	Time	Source	Destination	Protocol	Length Info
156	146.740367	216.97.88.9	10.12.19.101	SMTP	144 S: 553 5.3.0 Email blocked us

Frame 156: 144 bytes on wire (1152 bits), 144 bytes captured (1152 bits)
 Ethernet II, Src: Netgear_b6:93:f1 (20:e5:2a:b6:93:f1), Dst: HewlettP_1c:47:ae (00:08:02:1c:47:ae)
 Internet Protocol Version 4, Src: 216.97.88.9, Dst: 10.12.19.101
 Transmission Control Protocol, Src Port: 25, Dst Port: 49171, Seq: 220, Ack: 58, Len: 90
 Simple Mail Transfer Protocol
 Response: 553 5.3.0 Email blocked using spamhaus.org - see <http://www.spamhaus.org> 173.66.46.112\r\n
 Response code: Requested action not taken: mailbox name not allowed (553)
 Response parameter: 5.3.0 Email blocked using spamhaus.org - see <http://www.spamhaus.org> 173.66.46.112

Based on the packet from the previous question, what is the full Response
 code: message? Requested action not taken: mailbox name not allowed (553)

Search for response code 552. How many messages were blocked for presenting potential security issues? 6



No.	Time	Source	Destination	Protocol
376	276.497486	173.194.66.27	10.12.19.101	SMTP
541	277.290110	173.194.66.27	10.12.19.101	SMTP
687	279.559689	173.194.66.27	10.12.19.101	SMTP
880	290.423089	74.125.138.27	10.12.19.101	SMTP
999	301.303854	173.194.66.27	10.12.19.101	SMTP
1121	313.541268	64.233.180.27	10.12.19.101	SMTP

Task 7 - Inspecting Emails and Attachments

In this task, you'll move beyond SMTP status codes and responses and begin analyzing SMTP traffic using the same traffic capture from the task above. You will utilize the **Internet Message Format (IMF)**([opens in new tab](#))) to examine the inner details of emails, such as sender and recipient fields, content type, and attachments.

Answer the questions below

How many SMTP packets are available for analysis? 512

smtp

	Time	Source	Destination	Protocol	Length Info
	79.128.555770	17.171.2.68	10.12.19.101	SMTP	87 S: 421 4.4.2 Connection read error
	83.128.873360	17.151.62.68	10.12.19.101	SMTP	142 S: 554 550 Blocked - see https://support.proof
	91.129.916400	17.151.62.68	10.12.19.101	SMTP	87 S: 421 4.4.2 Connection read error
	95.129.230235	17.151.62.67	10.12.19.101	SMTP	142 S: 554 550 Blocked - see https://support.proof
	101.129.381113	17.151.62.67	10.12.19.101	SMTP	87 S: 421 4.4.2 Connection read error
	107.129.563915	17.151.62.66	10.12.19.101	SMTP	142 S: 554 550 Blocked - see https://support.proof
	119.129.796405	17.151.62.66	10.12.19.101	SMTP	87 S: 421 4.4.2 Connection read error
	121.129.858187	17.171.2.60	10.12.19.101	SMTP	142 S: 554 550 Blocked - see https://support.proof
	127.129.946560	17.171.2.60	10.12.19.101	SMTP	87 S: 421 4.4.2 Connection read error
	131.130.135263	17.171.2.72	10.12.19.101	SMTP	142 S: 554 550 Blocked - see https://support.proof
	137.130.221402	17.171.2.72	10.12.19.101	SMTP	87 S: 421 4.4.2 Connection read error
	150.146.508060	216.97.88.9	10.12.19.101	SMTP	132 S: 220 unicode.org ESMTP Sendmail Secure/Rabid
	151.146.508500	10.12.19.101	216.97.88.9	SMTP	72 C: EHLO unicode.org
	153.146.622476	216.97.88.9	10.12.19.101	SMTP	195 S: 250-unicode.org Hello r-112-46-66-173.consu
	154.146.623223	10.12.19.101	216.97.88.9	SMTP	93 C: MAIL FROM:<MAILER-DAEMON@unicode.org>
	156.146.740367	216.97.88.9	10.12.19.101	SMTP	144 S: 553 5.3.0 Email blocked using spamhaus.org
	161.164.700025	172.160.147.170	10.12.19.101	SMTP	220 S: 220 host.oclabs.net ESMTP Exim 4.04 #1 blo

Frame 156: 144 bytes on wire (1152 bits), 144 bytes captured (1152 bits)

Ethernet II, Src: Netgear_b6:93:f1 (20:e5:2a:b6:93:f1), Dst: HewlettPc_1c:47:ae (00:08:02:1c:47:ae)

Internet Protocol Version 4, Src: 216.97.88.9, Dst: 10.12.19.101

Transmission Control Protocol, Src Port: 25, Dst Port: 49171, Seq: 220, Ack: 58, Len: 90

Source Port: 25

Destination Port: 49171

[Stream index: 13]

[TCP Segment Len: 90]

Sequence number: 220 (relative sequence number)

Sequence number (raw): 1881065072

[Next sequence number: 310 (relative sequence number)]

Acknowledgment number: 58 (relative ack number)

Acknowledgment number (raw): 982533430

0101 = Header Length: 20 bytes (5)

Flags: 0x018 (PSH, ACK)

000. = Reserved: Not set

...0 = Nonce: Not set

....0... = Congestion Window Reduced (CWR): Not set

00	00	08	02	1c	47	ae	20	e5	2a	b6	93	f1	08	00	45	00	...	G	.	*		E
10	00	82	0c	b0	00	00	80	06	df	ea	d8	61	58	09	0a	0c	...		a	X	...	
20	13	65	00	19	c0	13	70	1e	c6	70	3a	90	45	36	50	18	...	e	...	p	:	E6P
30	fa	f0	09	37	00	00	35	35	33	20	35	2e	33	2e	30	20	...	7	...	55	3	5.3.0
40	45	6d	61	69	6c	20	62	6c	6f	63	6b	65	64	20	75	73	...	E	m	a	i	l
50	69	6e	67	20	73	70	61	6d	68	61	75	73	2e	6f	72	67	...	i	n	g	s	p
60	20	2d	20	73	65	65	20	3c	68	74	74	70	3a	2f	2f	77	...	-	s	e	e	<
70	77	77	2e	73	70	61	6d	68	61	75	73	2e	6f	72	67	3e	...	w	w	.	s	p
80	20	31	37	33	2e	36	36	2e	34	36	2e	31	31	32	0d	0a	...	173.66.	46.112	...		

Simple Mail Transfer Protocol: Protocol

Packets: 1637 · Displayed: 512

What is the name of the attachment in packet 270? document.zip

0540	37	33	44	34	43	0d	0a	43	6f	6e	74	65	6e	74	2d	54	73D4C...	C	o	n	t	e	n	t	-1								
0550	79	70	65	3a	20	61	70	70	6c	69	63	61	74	69	6f	6e	...	y	p	e	:	a	p	p	l	i	c	a	t	i	o	n	
0560	2f	6f	63	74	65	74	2d	73	74	72	65	61	6d	3b	0d	0a	...	/	o	c	t	e	t	-	s	t	r	e	a	m			
0570	09	6e	61	6d	65	3d	22	64	6f	63	75	6d	65	6e	74	2e	...	.	n	a	m	e	=	"	d	o	c	u	m	e	n	t	
0580	7a	69	70	22	0d	0a	43	6f	6e	74	65	6e	74	2d	54	72	...	z	i	p	"	.	C	o	n	t	e	n	t	-	T	r	
0590	61	6e	73	66	65	72	2d	45	6e	63	6f	64	69	6e	67	3a	...	a	n	s	f	e	r	-	E	n	c	o	d	i	n	g	
05a0	20	62	61	73	65	36	34	0d	0a	43	6f	6e	74	65	6e	74	...	b	a	s	e	64	.	.	C	o	n	t	e	n	t		
05b0	2d	44	69	73	70	6f	73	69	74	69	6f	6e	3a	20	61	74	...	-	D	i	s	p	o	s	i	t	i	o	n	:	a	t	
05c0	74	61	63	68	6d	65	6e	74	3b	0d	0a	09	66	69	6c	65	...	a	t	t	a	c	h	m	e	n	t	;	...	f	i	l	e
05d0	6e	61	6d	65	3d	22	64	6f	63	75	6d	65	6e	74	2e	7a	...	n	a	m	e	=	"	d	o	c	u	m	e	n	t	.	z
05e0	69	70	22	0d	0a	0d	0a	55	45	73							...	i	p	"	...	U	E	s									

According to the message in packet 270, which Host IP address is not responding, making the message undeliverable? 212.253.25.152

```

not reachable within the allowed queue period. The amount of time\r\n
a message is queued before it is returned depends on local configura-\r\n
tion parameters.\r\n
\r\n
Most likely there is a network problem that prevented delivery, but\r\n
it is also possible that the computer is turned off, or does not\r\n
have a mail system running right now.\r\n
\r\n
Your message was not delivered within 5 days:\r\n
Host 212.253.25.152 is not responding.\r\n
\r\n
The following recipients did not receive this message:\r\n
<talkback@mozilla.org>\r\n
\r\n
Please reply to postmaster@mozilla.org\r\n
if you feel this message to be in error.\r\n
\r\n
\r\n
73 3a 0d 0a 48 6f 73 74 20 32 31 32 2e 32 35 33 s:..Host 212.253
2e 32 35 2e 31 35 32 20 69 73 20 6e 6f 74 20 72 .25.152 is not r
65 73 70 6f 6e 64 69 6e 67 2e 0d 0a 0d 0a 54 68 espondin g...Th
65 20 66 6f 6c 6c 6f 77 69 6e 67 20 72 65 63 69 e follow ing reci

```

By filtering for imf, which email client was used to send the message containing the attachment attachment.scr? Microsoft Outlook Express 6.00.2600.0000

Which type of encoding is used for this potentially malicious attachment?
base64

Task 8 - How Organizations Stop Phishing

Now that you've explored how emails are authenticated through mechanisms like SPF, DKIM, and DMARC, and analyzed real SMTP traffic and message contents, let's explore some modern solutions that enhance email security and reduce phishing risks.

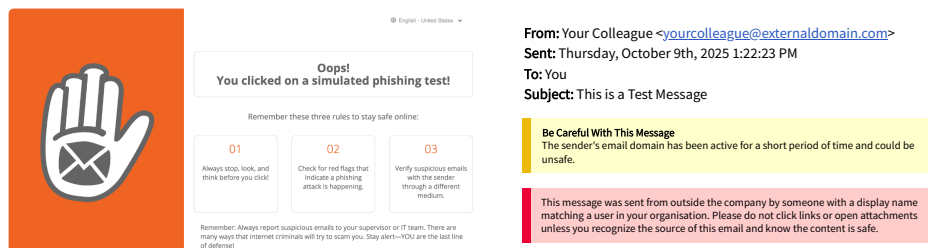
Technical Defenses: Modern email systems employ various technical controls to help detect and block phishing messages before they reach users.

- **Email Filtering**([opens in new tab](#)): Provides filtering based on IP and domain reputation, allowing for blocking or quarantining of suspicious messages.
- **Secure Email Gateways**([opens in new tab](#)) (SEGs): Scan messages to detect impersonation attempts, spoofing, and other phishing techniques that other filters might miss.
- **Link Rewriting**([opens in new tab](#)): Replaces suspicious or unknown URLs with safe, redirected ones, giving the system time to scan and verify the link.

- **Sandboxing**(opens in new tab): Isolates and tests suspicious links or attachments in a secure, virtual environment to check for malicious behavior.

User-Facing Tools & Training: Even with strong technical defenses in place, some phishing emails will inevitably reach users. Giving users clear visual cues and education is essential.

- **Trust & Warning Indicators:** Modern email platforms display visual cues to help users understand if a message is safe. A banner may read "External Sender," "Suspicious Link," or signify that a message is from a trusted organization or sender.
- **Phishing Reporting:** Easy, in-email reporting options that let users quickly report suspicious messages.
- **User Awareness Training:** Train employees on identifying phishing attempts, social engineering tactics, and safe email practices.
- **Phishing Simulation Exercises:** Run controlled phishing campaigns to test and reinforce employee training.



Answer the questions below

A security team wants to implement a control to detect hidden malware inside email attachments.

They need a way to analyze suspicious files without risking infection on real systems.

Which protective technique would allow them to observe a file's behavior safely?

Sandboxing

Task 9 - Conclusion

In this room, you explored how technologies like SPF, DKIM, DMARC, and S/MIME work together to authenticate email and protect users against phishing. You then learned how to interpret SMTP response codes and analyze SMTP traffic to understand how email servers handle messages. Finally, you examined the tools and technologies organizations use to detect and prevent phishing attempts, combined with user-focused awareness and reporting mechanisms.

Essential SOC Analyst OSINT Toolkit (Most Used)

VirusTotal

AbuseIPDB

[URLScan.io](https://urlscan.io)

Shodan

Whois

IPinfo

Talos Intelligence

AlienVault OTX

MalwareBazaar

URLhaus

ThreatFox

ANY.RUN

Hybrid Analysis

GreyNoise

Censys

crt.sh

MXToolbox

CyberChef

MITRE ATT&CK

Google/Microsoft Header Analyzer

SOC Investigation Flow:

 Phishing Email → Header Analysis → URL Extraction → Domain/IP Reputation → Sandbox Analysis → IOC Enrichment → MITRE ATT&CK Mapping → SIEM Detection Rule Creation.

Cybersecurity OSINT Tools

IP Address Intelligence & Reputation and Domain, DNS & Infrastructure Intelligence

VirusTotal — Analyze files, URLs, IPs, and domains for malware reputation

WhereGoes — Trace URL redirects and hidden destination links

IPinfo — Retrieve IP address geolocation and network intelligence

urlscan.io — Scan and analyze websites for threats and behavior

AbuseIPDB — Check IP addresses reported for malicious activity

Shodan — Search internet-connected devices and exposed services

[Whois.com](https://whois.com) — Find domain ownership and registration information

MalwareBazaar — Search and analyze malware samples and hashes

MXToolbox — Analyze DNS records, email security, and blacklist status

Cisco Talos Intelligence Reputation Center — Check IP, domain, and file reputation intelligence

Microsoft Header Analyzer — Analyze email headers and trace message paths

crt.sh — Search SSL certificates and discover subdomains

Google Message Header Analyzer — Investigate email routing and authentication headers

Malware Sandbox Analysis Tools

ANY.RUN — Interactive malware analysis in a controlled environment

Hybrid Analysis — Automated malware behavior and threat analysis

Joe Sandbox — Deep malware analysis with behavioral reports

PhishTool — Analyze phishing emails and malicious indicators

Email Security & Authentication Analysis

DMARCian SPF Survey — Validate SPF records and email sender policies

DMARCian DKIM Inspector Check — DKIM signatures and email authentication

Google Message Header Analyzer — Investigate email headers for phishing analysis

Email / Phishing Investigation Additions

PhishGuardian — AI-powered phishing analysis and investigation platform for detecting, analyzing, and responding to email-based threats.

MailTester — Test email deliverability and authentication

[EmailRep.io](#) — Check email reputation and risk scoring

PhishTank — Verify known phishing websites

Threat Hunting & IOC Investigation

MISP — Share and manage threat intelligence indicators

OpenCTI — Model cyber threats and intelligence relationships

MITRE ATT&CK — Map attacker behaviors and techniques

MITRE D3FEND — Map defensive countermeasures against attacks

CyberChef — Decode, transform, and analyze data artifacts